

Web Services

HTTP, Request Headers, RESTful Web Services, Swagger



REST API

SoftUni Team

Technical Trainers



SoftUni

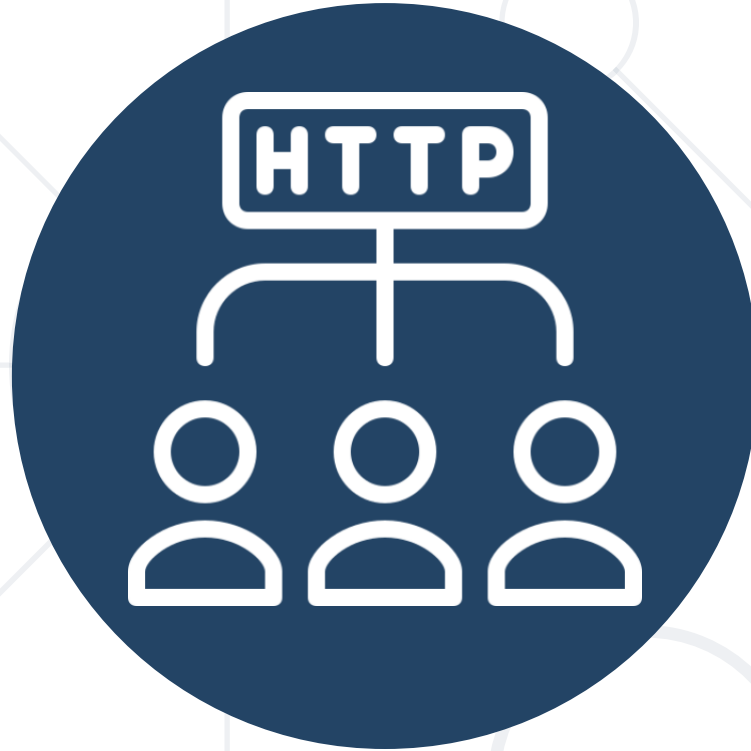


Software University

<https://softuni.bg>

1. **HTTP** Overview
2. **HTTP** Developer Tools
3. Introduction to **RESTful Services**
4. Authentication and Authorization in RESTful APIs
5. Swagger

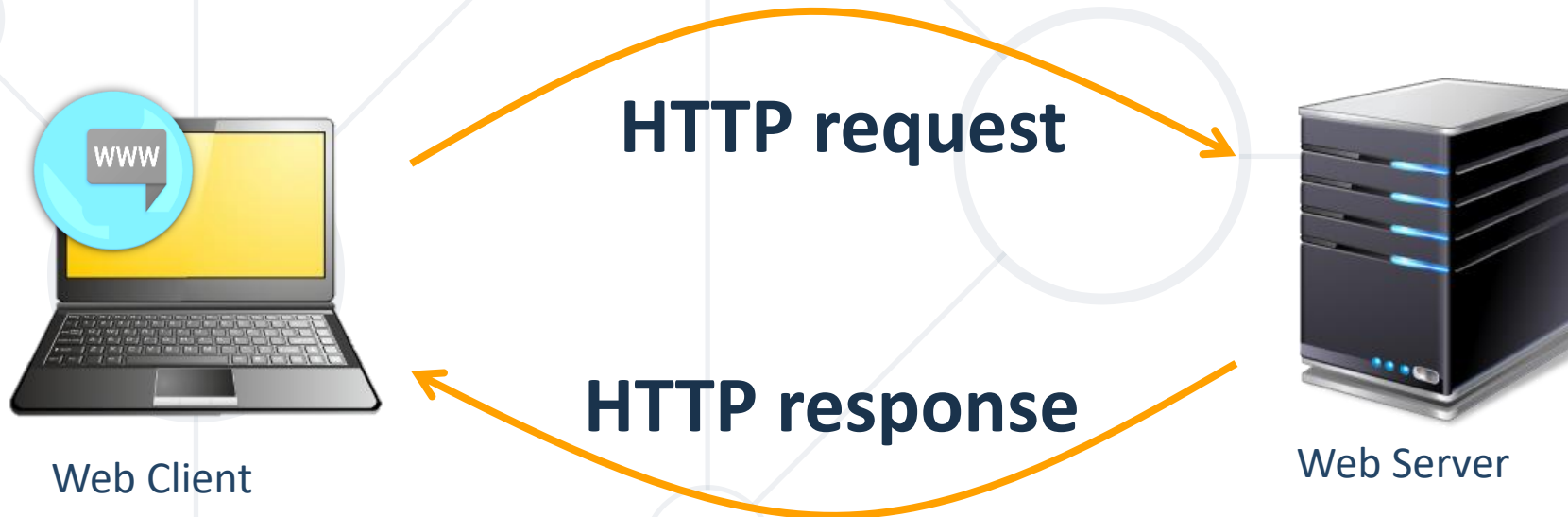




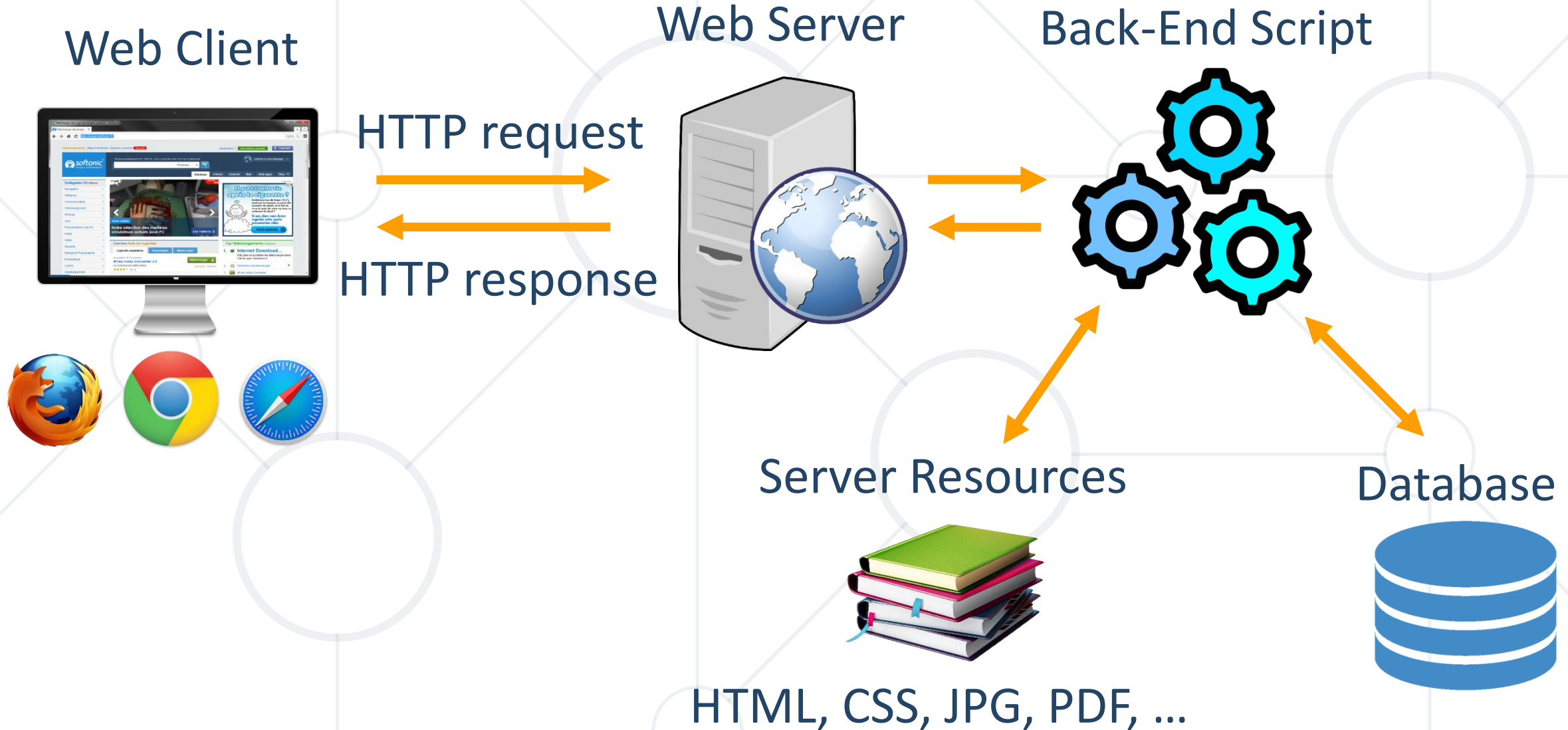
HTTP Overview

Hypertext Transfer Protocol

- HTTP (**H**yper **T**ext **T**ransfer **P**rotocol)
 - Text-based client-server protocol for the Internet
 - For transferring Web resources (HTML files, images, styles, etc.)
 - Request-response based



Web Server Work Model



HTTP Request Methods

- **HTTP request methods** specify the desired **action** to be performed on the requested resource (identified by URL)

Method		Description	CRUD == the four main functions of persistent storage	Other Methods	
GET		Retrieve a resource		CONNECT	
POST		Create / store a resource		OPTIONS	
PUT		Update (replace) a resource		TRACE	
DELETE		Delete (remove) a resource			
PATCH		Update resource partially (modify)			
HEAD		Retrieve the resource's headers			

HTTP Response Status Codes

Status Code	Action	Description	
200	OK	Successfully retrieved resource	} Success
201	Created	A new resource was created	
204	No Content	Request has nothing to return	
301 / 302	Moved	Moved to another location (redirect)	} Redirect
400	Bad Request	Invalid request / syntax error	} Error
401 / 403	Unauthorized	Authentication failed / access denied	
404	Not Found	Invalid resource requested	
409	Conflict	Conflict detected, e.g. duplicated email	
500 / 503	Server Error	Internal server error / service unavailable	

Content-Type and Disposition

- The **Content-Type** / **Content-Disposition** headers specify how the HTTP request / response body should be processed

JSON-encoded data

Content-Type: **application/json**

UTF-8 encoded HTML page.
Will be shown in the browser

Content-Type: **text/html**; charset=utf-8

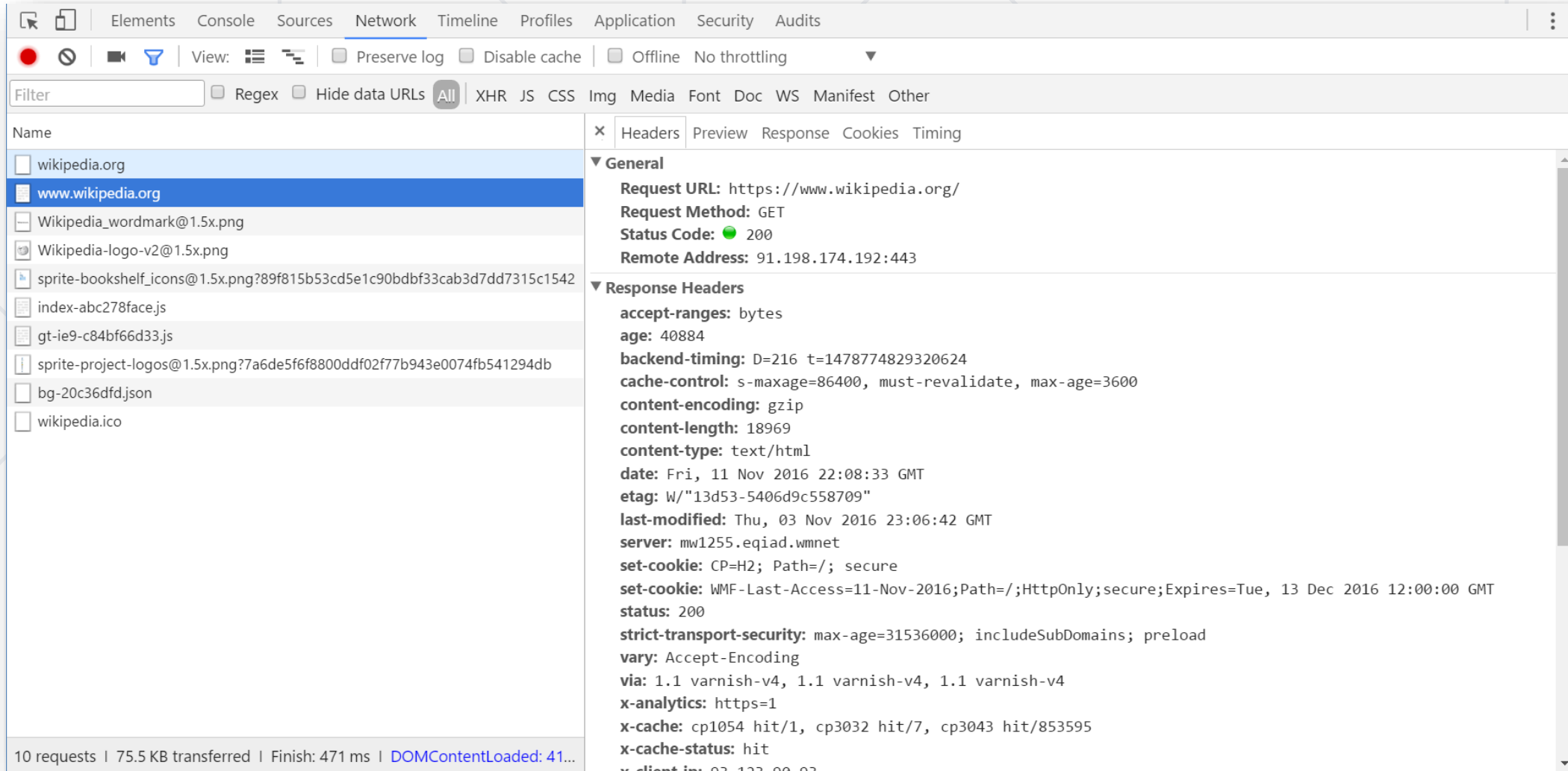
Content-Type: **application/pdf**

Content-Disposition: attachment;

filename="Financial-Report-April-2016.pdf"

This will download a PDF file named
Financial-Report-April-2016.pdf

Browser Developer Tools



The screenshot shows the Chrome DevTools Network tab. The left pane lists network requests, with `www.wikipedia.org` selected. The right pane shows the details for this request, including the General tab with the following information:

- Request URL:** `https://www.wikipedia.org/`
- Request Method:** `GET`
- Status Code:** `200`
- Remote Address:** `91.198.174.192:443`

The **Response Headers** section is expanded, showing the following headers:

- accept-ranges:** `bytes`
- age:** `40884`
- backend-timing:** `D=216 t=1478774829320624`
- cache-control:** `s-maxage=86400, must-revalidate, max-age=3600`
- content-encoding:** `gzip`
- content-length:** `18969`
- content-type:** `text/html`
- date:** `Fri, 11 Nov 2016 22:08:33 GMT`
- etag:** `W/"13d53-5406d9c558709"`
- last-modified:** `Thu, 03 Nov 2016 23:06:42 GMT`
- server:** `mw1255.eqiad.wmnet`
- set-cookie:** `CP=H2; Path=/; secure`
- set-cookie:** `WMF-Last-Access=11-Nov-2016; Path=/; HttpOnly; secure; Expires=Tue, 13 Dec 2016 12:00:00 GMT`
- status:** `200`
- strict-transport-security:** `max-age=31536000; includeSubDomains; preload`
- vary:** `Accept-Encoding`
- via:** `1.1 varnish-v4, 1.1 varnish-v4, 1.1 varnish-v4`
- x-analytics:** `https=1`
- x-cache:** `cp1054 hit/1, cp3032 hit/7, cp3043 hit/853595`
- x-cache-status:** `hit`
- x-client-ip:** `92.122.80.92`

The bottom status bar indicates: 10 requests | 75.5 KB transferred | Finish: 471 ms | DOMContentLoaded: 41...



Introduction to RESTful Services

Mapping CRUD Operations

What is an API?



- **Application Programming Interface**
 - **APIs** – Mechanisms that enable **two software components** to **communicate with each other** using a set of definitions and **protocols**
- **APIs in everyday life**
 - Social media bots
 - Third-party login
 - E-commerce transactions
 - Weather apps

What is RESTful API?

- An **application programming interface** that follows the principles of **REpresentational State Transfer**
- **REST** - a set of guidelines for designing web services that are **scalable, uniform, and stateless**
- Allows clients to **access and manipulate resources** on a server using standard **HTTP methods** – **GET, POST, PUT, and DELETE**
- **Resource** - anything that has a **unique identifier**, such as a user, a product, or a post

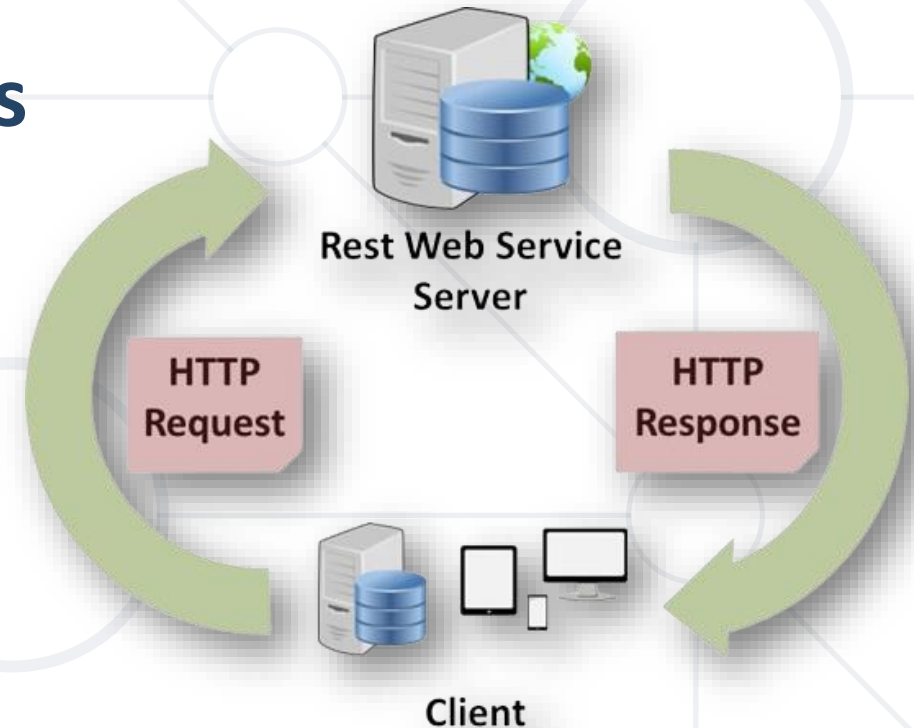


REST - Communication Standard

- **REST** - the most common communication standard between computers over Internet
- The **common API standard** used by most mobile and web applications to **talk to the servers** is called REST



- In **REST architecture**, a **REST Server** simply **provides access to resources** and **REST client** accesses and modifies the resources
- Each resource is identified by **URIs / global IDs**
- REST uses various **formats to represent a resource** like text, JSON, XML...

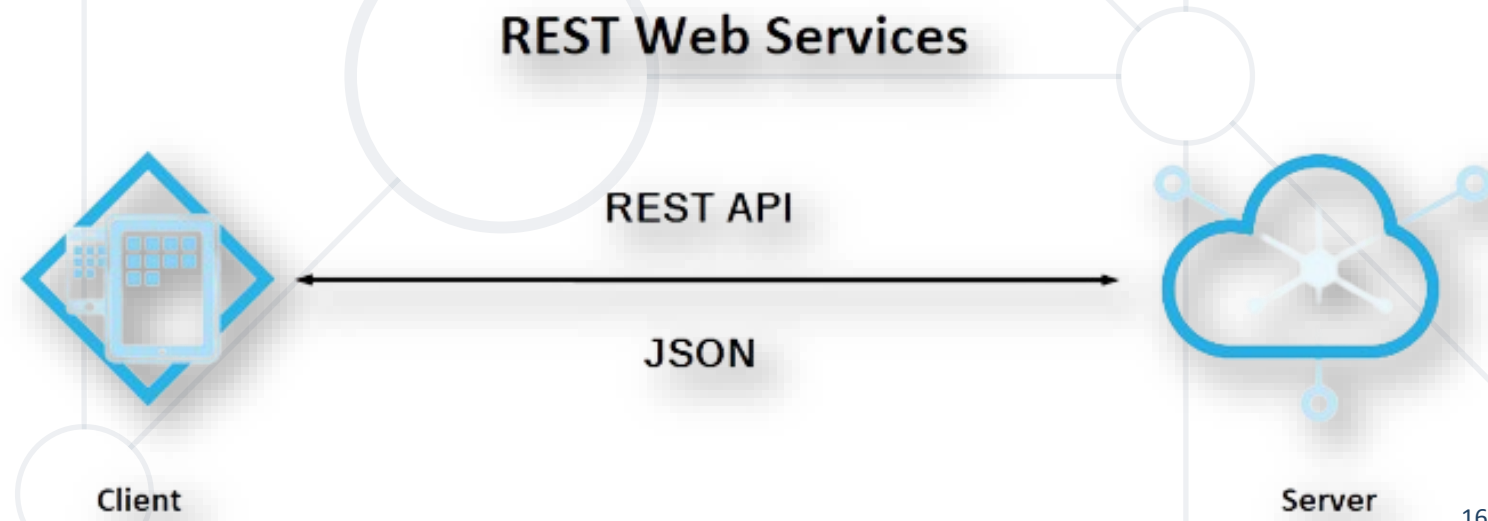


HTTP Methods → CRUD Operations

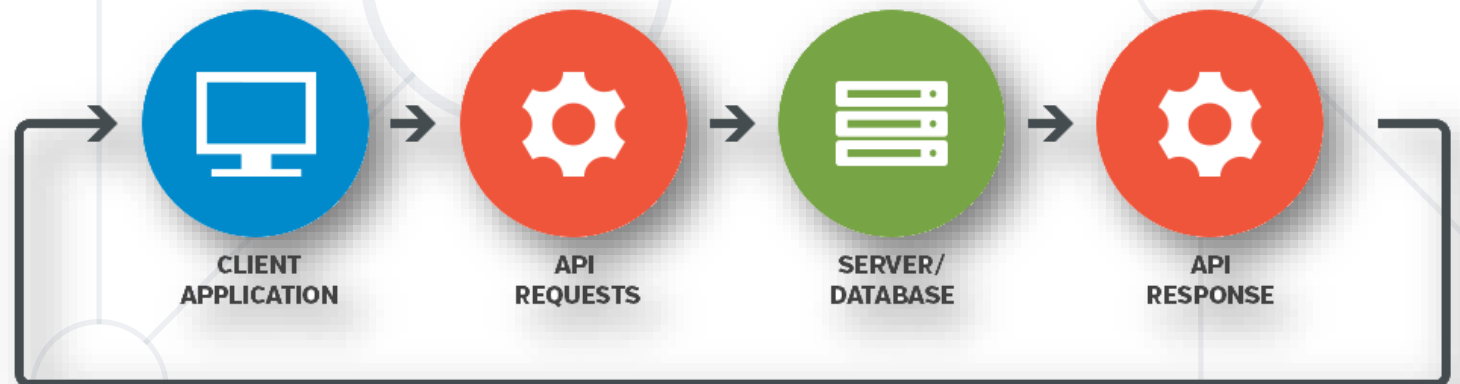
- The following **HTTP methods** are commonly used in **REST-based architecture**:
 - **POST** – Used to **create** a new resource
 - **GET** – Provides a **read-only access** to a resource
 - **PUT** – Used to **update** an existing resource or create a new resource
 - **DELETE** – Used to **remove** a resource

Create	→	POST	HTTP Methods
Read	→	GET	
Update	→	PUT	
Delete	→	DELETE	

- **REST Web Service**
 - A **lightweight, maintainable, and scalable** service
 - Built on the **REST architecture**
- **Expose API** from an application **to the calling client** in a
 - Secure
 - Uniform
 - Stateless manner



- **Web services** expose **back-end APIs** over the **network**
 - May use different **protocols** and **data formats**: HTTP, REST, GraphQL, gRPC, SOAP, JSON-RPC, JSON, BSON, XML, YML, ...
- **Web services** are hosted on a Web server (HTTP server)
 - Provide a set of functions, invocable from the Web (Web API)
- **RESTful APIs** is the most popular Web service standard





Authentication and Authorization

RESTful APIs

Authentication



- The process of **verifying the identity** of a user or a system
- This process **often** involves checking whether a **username and password provided are correct**
- **In RESTful services**, authentication can be achieved through various methods, including
 - Basic authentication (using a base64 encoded **username and password**)
 - **Tokens** such as JSON Web Tokens (JWTs)
 - **HMAC** (hash-based message **authentication codes**)

Authorization

- **Authorization** - granting an **authenticated user permission** to access different resources or perform specific actions
- Once a user is **authenticated**, the system must check **what resources** the user is allowed to access or **what actions** they are permitted to perform
- It's important to note that both **authentication** and **authorization** mechanisms must be **protected with HTTPS** to prevent **man-in-the-middle attacks** and to ensure that sensitive information is transmitted securely



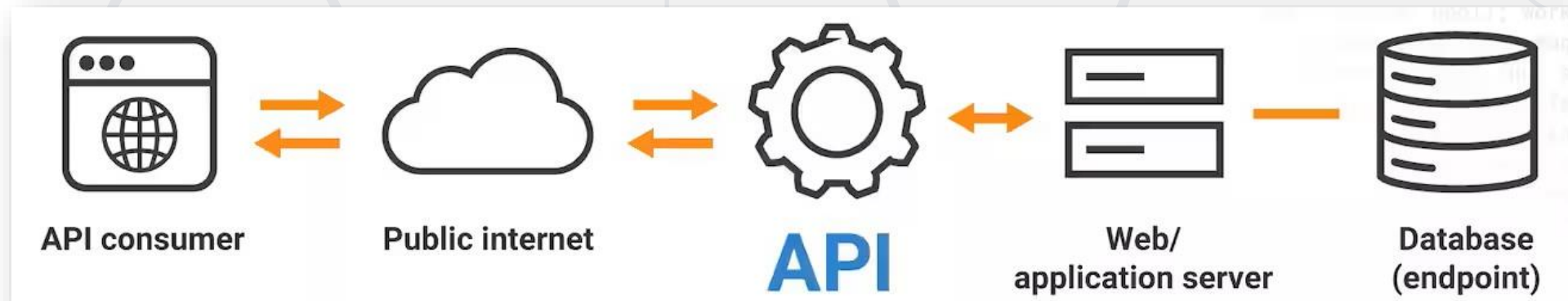
■ Authentication

- Determines **whether users are** who they claim to be
- Generally, transmits info through an **ID Token**
- Usually done before authorization

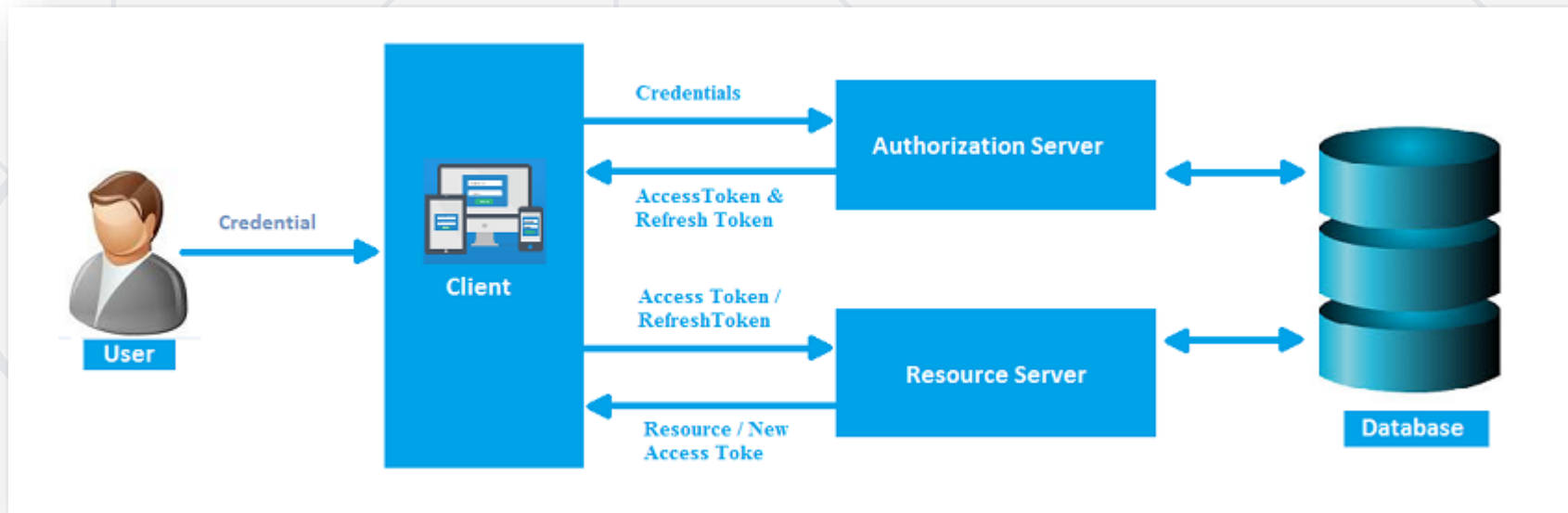
■ Authorization

- Determines **what users can and cannot access**
- Generally, transmits info through an **Access Token**
- Usually done after successful authentication

- **REST APIs** have become approach for modern **web** and **mobile application platforms**
- They **separate data** and **presentation layers**, allowing systems to scale in size and feature sophistication over time
- As **data moves across boundaries**, **security** becomes a **key concern** for REST APIs containing **sensitive information**



- One of the most straightforward ways to secure these APIs is to implement **authentication mechanisms** that control their exposure
- Mainly through **user credentials** and **encrypted access codes**



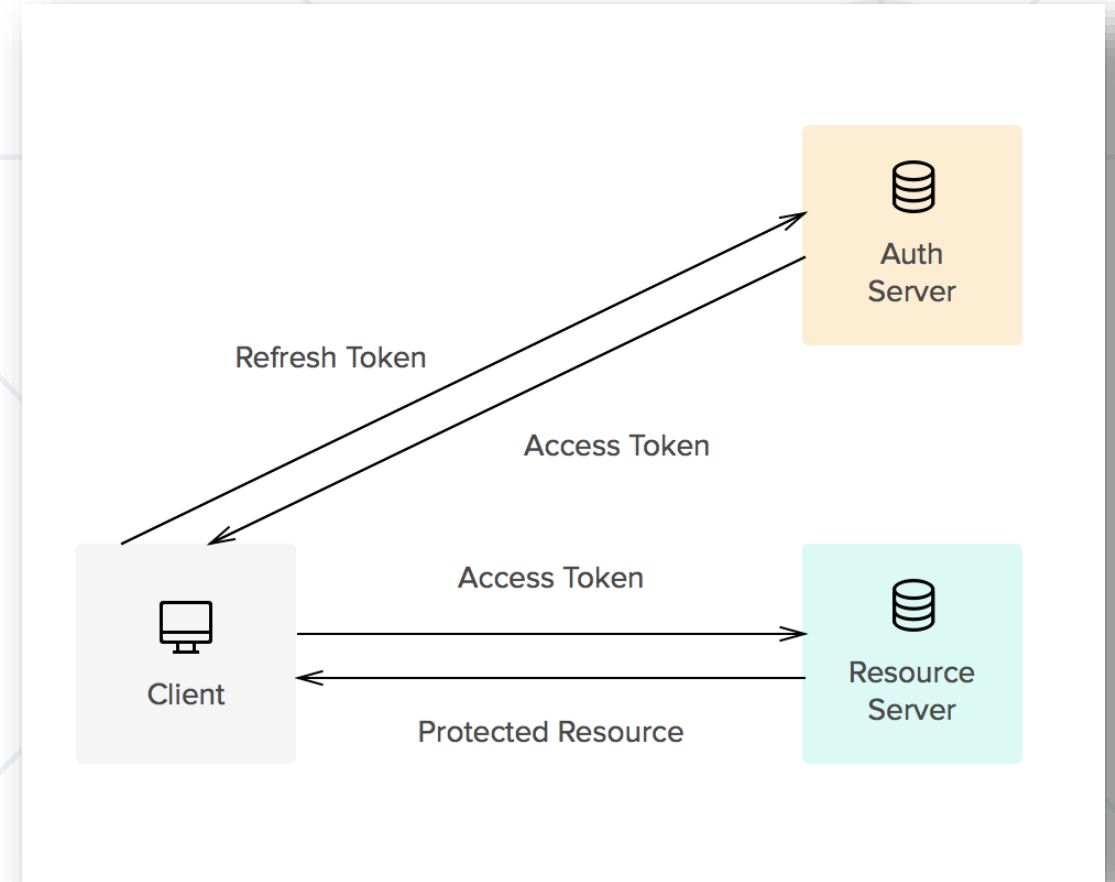
Token Authentication

- Token authentication is also known as **Bearer Authentication**
- To use it, you just specify Authorization:
 - **Bearer <token>**
- Token is a string that **represents the user's identity and permissions**
 - If you **have (bear) the token**, you can get the appropriate **access to the API**

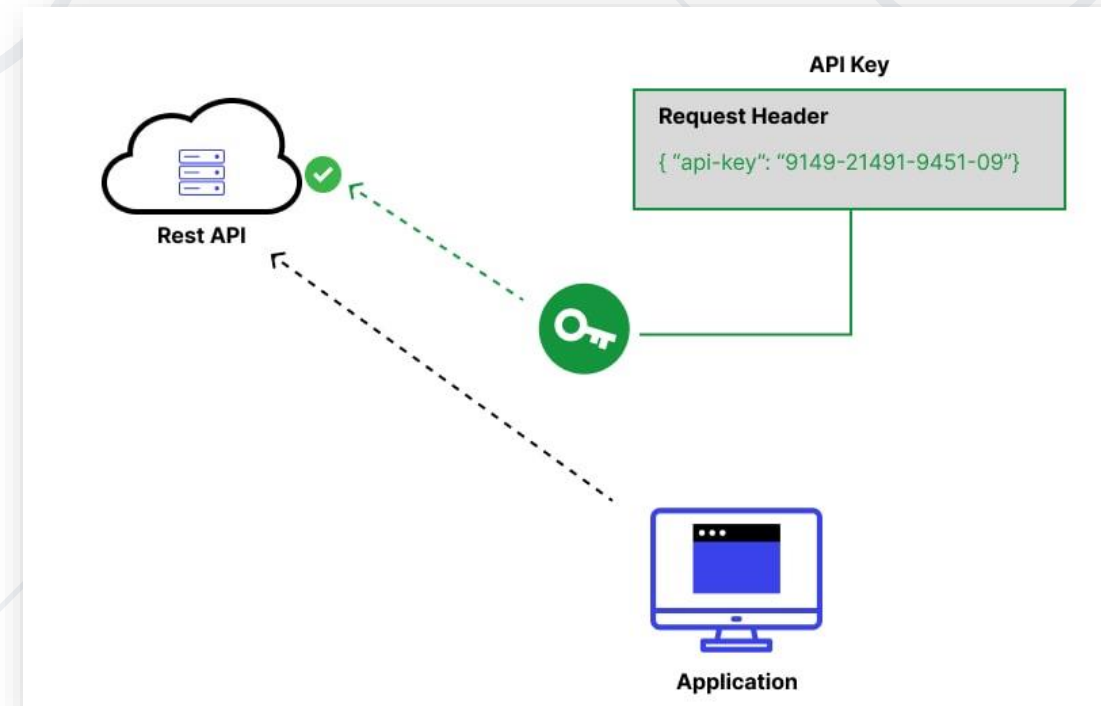


Bearer Authentication

- **Bearer Authentication** is a method of sending a token with **HTTP requests** to authenticate
- The token is a string, often in **JWT (JSON Web Token)** format, that the server can use to verify the request's authenticity and integrity



- After you prove the **user's identity**, you can check which data that user is **allowed to access**
- Authorization ensures that the **user is authorized** to **view** or **edit** a specific **set of data**





Swagger

API Documentation and Testing Tool

What is Swagger UI?

- Swagger is an **open-source framework** that helps developers **design, build, document, and consume RESTful web services**
- It simplifies **API development** by offering a **standardized approach to documenting APIs**
- Provides clear guidance for developers on **how to interact with an API**
- Reduces confusion and errors during integration



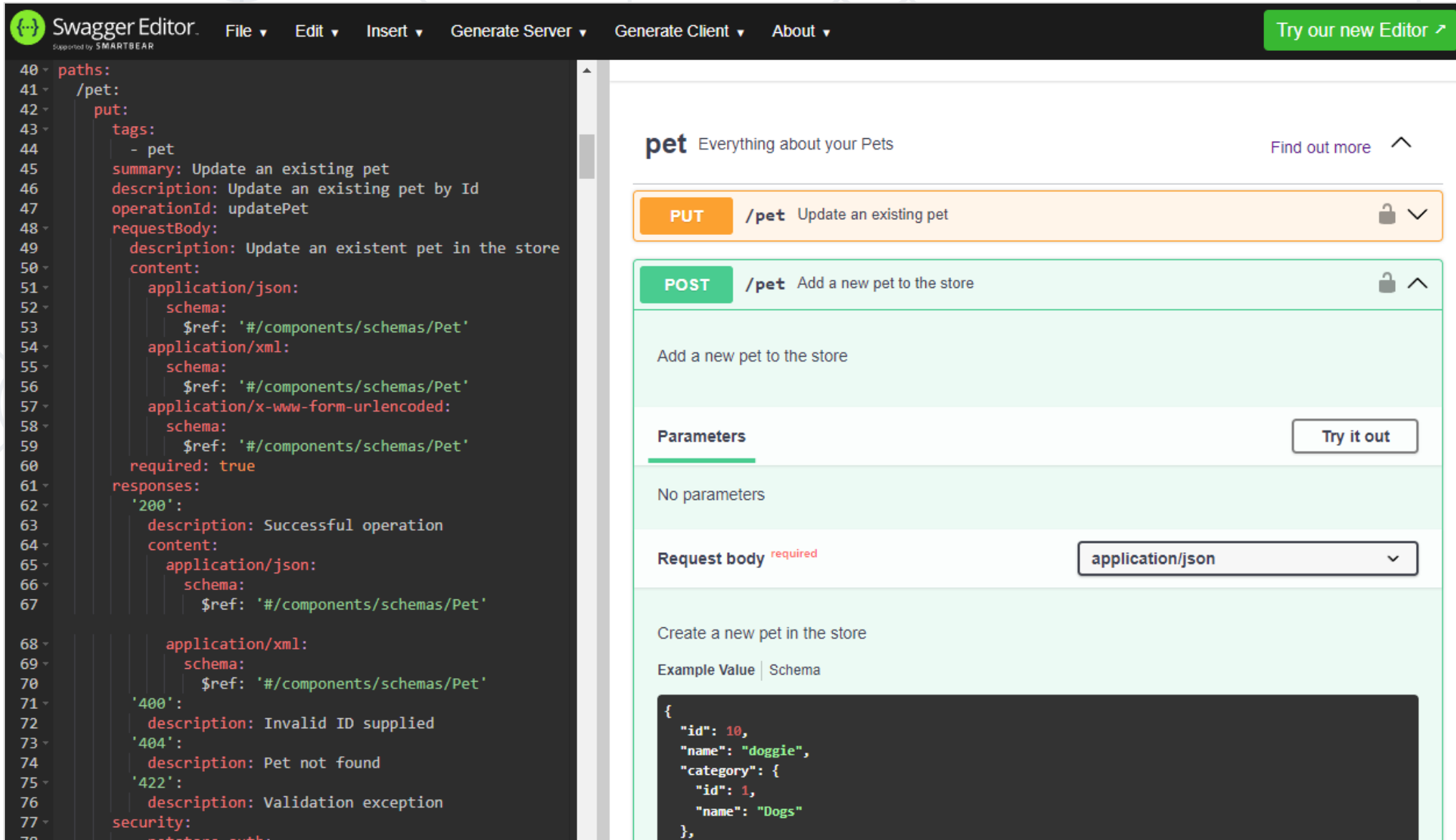
SwaggerTM

Benefits

- It creates **consistent documentation** across teams and projects
- Developers can try **API calls** directly in the browser with Swagger UI
- With tools like **Swagger Codegen**, you can automatically generate client SDKs and server stubs
- Validates **API requests** and **responses** against the API contract
- Teams can **work together** on API design and documentation



Swagger UI Example



The image shows the Swagger Editor interface on the left and the generated Swagger UI on the right.

Swagger Editor (Left):

```
40 paths:
41   /pet:
42     put:
43       tags:
44         - pet
45       summary: Update an existing pet
46       description: Update an existing pet by Id
47       operationId: updatePet
48       requestBody:
49         description: Update an existent pet in the store
50         content:
51           application/json:
52             schema:
53               $ref: '#/components/schemas/Pet'
54           application/xml:
55             schema:
56               $ref: '#/components/schemas/Pet'
57           application/x-www-form-urlencoded:
58             schema:
59               $ref: '#/components/schemas/Pet'
60         required: true
61       responses:
62         '200':
63           description: Successful operation
64           content:
65             application/json:
66               schema:
67                 $ref: '#/components/schemas/Pet'
68             application/xml:
69               schema:
70                 $ref: '#/components/schemas/Pet'
71         '400':
72           description: Invalid ID supplied
73         '404':
74           description: Pet not found
75         '422':
76           description: Validation exception
77       security:
```

Swagger UI (Right):

The UI displays the **pet** endpoint with the description "Everything about your Pets". It shows two methods:

- PUT /pet**: Update an existing pet. This method is currently selected and highlighted in orange.
- POST /pet**: Add a new pet to the store. This method is highlighted in green.

For the selected **PUT /pet** method, the UI shows:

- A description: "Update an existing pet".
- A "Parameters" section indicating "No parameters".
- A "Request body" section marked as "required", with a dropdown menu set to "application/json".
- An example value for the request body:

```
{
  "id": 10,
  "name": "doggie",
  "category": {
    "id": 1,
    "name": "Dogs"
  },
}
```

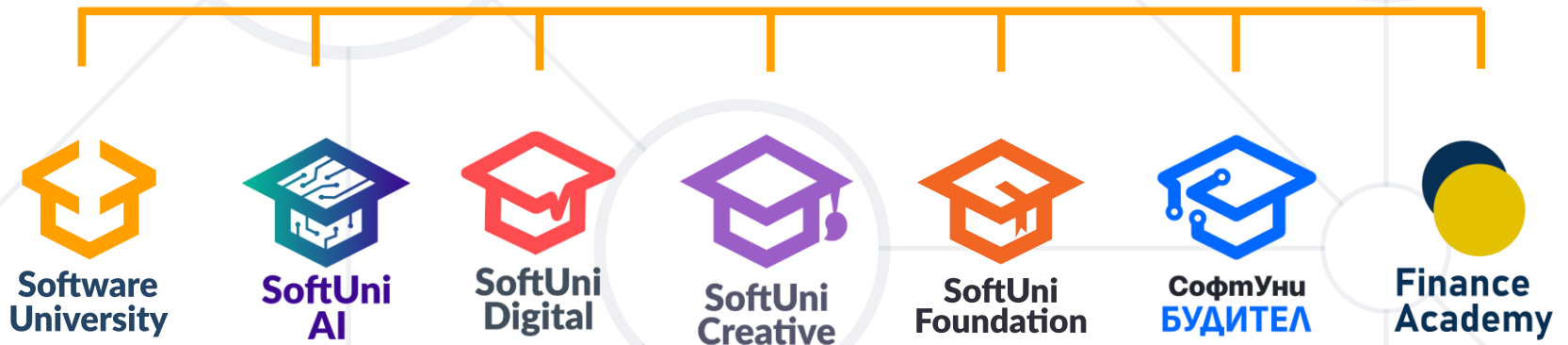
- Hypertext Transfer Protocol
- **HTTP** Response Status Codes
- **RESTful Services** – Introduction
- **RESTful APIs**
- **Authentication** and **Authorization** in REST API



Questions?



SoftUni



- Software University – High-Quality Education, Profession and Job for Software Developers

- softuni.bg, about.softuni.bg

- Software University Foundation

- softuni.foundation

- Software University @ Facebook

- facebook.com/SoftwareUniversity



Software University



- This course (slides, examples, demos, exercises, homework, documents, videos and other assets) is **copyrighted content**
- Unauthorized copy, reproduction or use is illegal
- © SoftUni – <https://softuni.org>
- © Software University – <https://softuni.bg>

